

THREAT ADVISORY

VULNERABILITY REPORT

RCE flaw in F5 BIG-IP and BIG-IQ

Date of Publication

November 17, 2022

Admiralty Code

A1

TA Number

TA2022263

Summary

First Seen: November 16, 2022

Affected Product: BIG-IP and BIG-IQ Centralized Management

Impact: Bypasses security constraints; remote code execution

CVEs

CVE	NAME	PATCH
CVE-2022-41622	Remote code execution via cross-site request forgery (CSRF)	
CVE-2022-41800	Remote code execution via RPM spec injection	

Vulnerability Details

Two security flaws in F5 BIG-IP and BIG-IQ can be exploited to enable remote code execution. An adversary could get persistent root access to the device's management interface by successfully exploiting the vulnerability (CVE-2022-41622), however this requires the attacker to know the address for a certain BIG-IP instance. Although the proof of concept is available, such an exploit requires an administrator with an active session visiting a rogue website.

Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-41622	BIG-IP (all modules) and BIG-IQ Centralized	cpe:2.3:a:f5:big- ip:*.~.*.*.*.*.*.*	CWE-352
CVE-2022-41800	Management: 8.0.0 - 8.2.0 & 7.1.0	cpe:2.3:a:f5:big- iq:*.~.*.*.*.*.*.*	CWE-77

Recommendations



Security Leaders

Asset and vulnerability management solutions should be implemented to ensure that all internet-accessible devices are secure, patched, updated, hardened, and monitored. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize the vulnerability, identify the impacted assets, and patch them through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Patch Details' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0008</u> Lateral Movement
<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities	<u>T1203</u> Exploitation for Client Execution	<u>T1190</u> Exploit Public-Facing Application
<u>T1574</u> Hijack Execution Flow	<u>T1210</u> Exploitation of Remote Services		

Patch Details

<https://support.f5.com/csp/article/K94221585>

<https://support.f5.com/csp/article/K13325942>

References

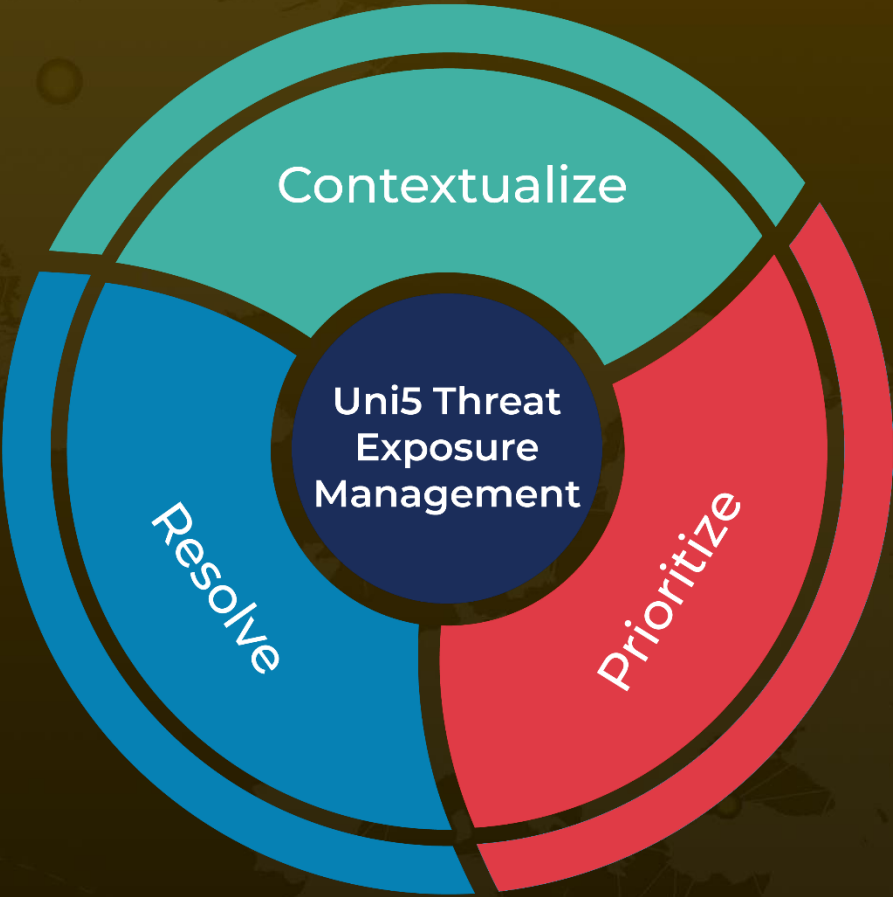
<https://www.rapid7.com/blog/post/2022/11/16/cve-2022-41622-and-cve-2022-41800-fixed-f5-big-ip-and-icontrol-rest-vulnerabilities-and-exposures/>

<https://thehackernews.com/2022/11/high-severity-vulnerabilities-reported.html>

What Next?

At HivePro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with Hive Pro Uni5: Continuous Threat Exposure Management Platform.



REPORT GENERATED ON

November 17, 2022 • 6:33 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com